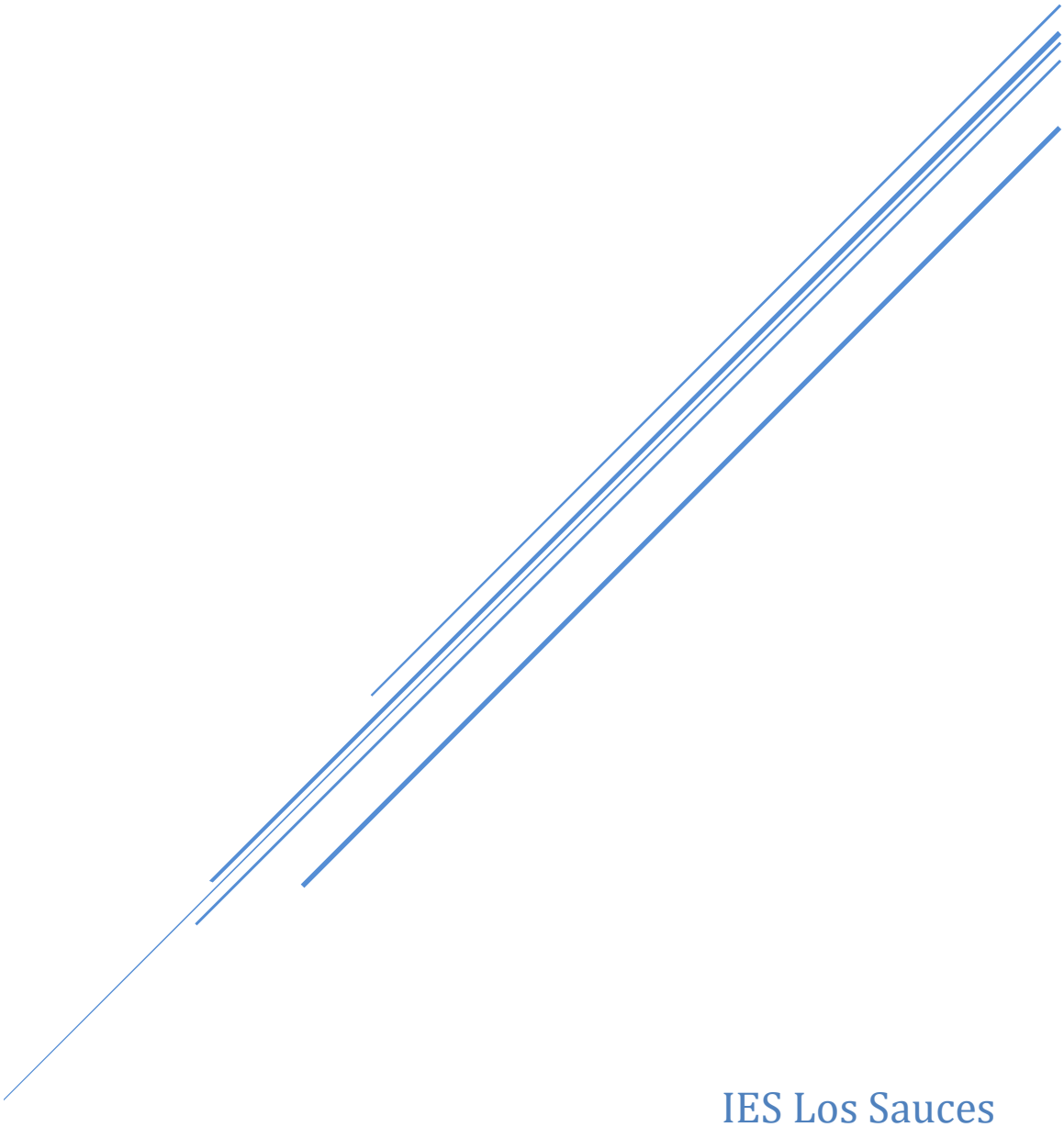
FUNDAMENTOS DE LA CIBERSEGURIDAD

Ejercicio 1.1



IES Los Sauces
DAW2

Índice

1. Amenazas y vulnerabilidades informáticas 2
2. Medidas de protección básicas. 3
3. Análisis de los incidentes de seguridad. 3
4. Herramientas y tecnologías de aplicación. 4
5. Normativa y buenas prácticas de uso 5
6. Auditorias de seguridad 5

1. Amenazas y vulnerabilidades informáticas

Amenazas: Son acciones maliciosas externas o internas (como malware, phishing o ingeniería social) que aprovechan esas vulnerabilidades para causar daño, robo de datos o interrupción de servicios.

Vulnerabilidades: Son debilidades internas en sistemas, redes, software o configuraciones (como errores de diseño, contraseñas débiles o fallos de validación) que pueden ser explotadas.

Confidencialidad: Garantiza que la información sensible solo sea accesible por personas o sistemas autorizados, protegiendo la privacidad mediante mecanismos como cifrado y controles de acceso.

Integridad: Asegura que los datos permanezcan precisos, consistentes y confiables durante todo su ciclo de vida, evitando alteraciones accidentales o maliciosas mediante validaciones y copias de seguridad.

Disponibilidad: Garantiza que los usuarios autorizados tengan acceso oportuno y continuo a los sistemas y datos cuando los necesiten, manteniendo la operatividad mediante redundancia y recuperación ante desastres.

Malware: Es cualquier programa diseñado intencionalmente para dañar sistemas informáticos, robar datos o tomar el control no autorizado de dispositivos sin el conocimiento del usuario. Existen varios tipos: Ransomware, Spyware…

Ingeniería social: Es una técnica de manipulación psicológica utilizada por ciberdelincuentes para engañar a las personas y obtener información confidencial, acceso a sistemas o realizar acciones que comprometan la seguridad.

DoS (Denegación de Servicio): Es un ciberataque que busca interrumpir un servicio en línea saturando un servidor con tráfico masivo generado desde una única fuente o dirección IP
DDoS (Denegación de Servicio Distribuido): Es una variante más compleja y potente que utiliza múltiples sistemas distribuidos geográficamente para atacar un único objetivo simultáneamente.

Man-in-the-Middle: Es un ciberataque donde un actor malicioso se interpone secretamente entre dos partes que se comunican, interceptando, leyendo o modificando los datos sin su conocimiento.
Exploit: Es un fragmento de código, software o técnica diseñada para aprovechar una vulnerabilidad (debilidad o fallo) en un sistema informático, red, aplicación o dispositivo con el fin de realizar acciones no autorizadas.

Inyección SQL (SQLi): Técnica de ataque que introduce código malicioso en entradas de usuario no validadas para manipular las consultas a la base de datos, permitiendo leer, modificar o destruir información sensible.

Cross-Site Scripting (XSS): Vulnerabilidad web que permite a un atacante inyectar scripts maliciosos (comúnmente JavaScript) en páginas vistas por otros usuarios, facilitando el robo de sesiones, cookies o la suplantación de identidad.

Cifrar: Proceso algorítmico de transformar datos legibles (texto claro) en un formato ininteligible (texto cifrado) para proteger su confidencialidad, accesible únicamente mediante una clave secreta.

Ransomware: Tipo de malware que secuestra el sistema o cifra los archivos de la víctima, exigiendo un rescate económico a cambio de la clave para descifrar la información.

2. Medidas de protección básicas.

Autenticación Multifactor (MFA): Método de seguridad que exige dos o más pruebas independientes para verificar la identidad del usuario: algo que sabe (contraseña), algo que tiene (móvil/token) o algo que es (biometría).

Roles y permisos: Modelo de control de acceso donde los *roles* son perfiles funcionales asignados a usuarios, y los *permisos* son las acciones concretas (leer, escribir, borrar) que cada rol puede ejecutar sobre recursos específicos.

Reglas de firewall: Instrucciones configuradas en un cortafuegos para permitir o bloquear el tráfico entrante o saliente según parámetros como origen, destino, puerto o protocolo.

Filtrado de puertos y protocolos: Mecanismo de red que evalúa los paquetes para permitir o denegar su paso analizando el protocolo de transporte (TCP, UDP, ICMP) y el número de puerto específico (ej. puerto 80 para HTTP).

Routers: Dispositivos de red que interconectan redes distintas y dirigen los paquetes de datos a lo largo de la mejor ruta física o lógica hacia su destino final.

Monitoreo y auditoría: Supervisión continua del estado y actividad de los sistemas para detectar anomalías en tiempo real (*monitoreo*), junto con la revisión periódica y sistemática de registros históricos (*auditoría*) para verificar el cumplimiento y la trazabilidad.

3. Análisis de los incidentes de seguridad.

Incidentes de seguridad: Cualquier evento que compromete o amenaza la confidencialidad, integridad o disponibilidad de la información o los sistemas informáticos.

Ciclo de vida de un incidente: Metodología estándar de respuesta compuesta por 6 fases:

1. *Detección:* Identificación de la anomalía o intrusión.
2. *Análisis:* Determinación del alcance, causa y gravedad del evento.
3. *Contención:* Aislamiento de los sistemas afectados para evitar que el daño se propague.
4. *Erradicación:* Eliminación completa del agente malicioso de la infraestructura.
5. *Recuperación:* Restauración de los servicios y datos a su estado operativo seguro.
6. *Aprendizaje:* Revisión posterior para documentar lecciones aprendidas y fortalecer las defensas.

Indicadores de compromiso (IoC): Evidencias digitales o restos forenses (direcciones IP maliciosas, hashes de archivos, claves de registro modificadas) que señalan que un sistema ha sido vulnerado.

Estrategias proactivas: Acciones de defensa planificadas con anterioridad al ataque (caza de amenazas, parches de seguridad, pruebas de penetración y simulaciones de phishing) orientadas a reducir vulnerabilidades antes de que sean explotadas.

Análisis forense: Aplicación de técnicas científicas de investigación y recolección de evidencia digital en discos duros, memoria o tráfico de red, preservando la cadena de custodia para determinar cómo ocurrió un incidente.

4. Herramientas y tecnologías de aplicación.

Cortafuegos (Firewall): Sistema de seguridad de red que monitorea y controla el tráfico entrante y saliente basándose en políticas de seguridad predeterminadas.

Basados en red: Hardware o software dedicado ubicado en el perímetro para proteger múltiples dispositivos dentro de una red local.

Basados en host: Software instalado directamente en un endpoint individual (servidor o PC) para controlar únicamente el tráfico que entra o sale de ese equipo.

IDS (Sistema de Detección de Intrusiones): Herramienta pasiva que monitoriza el tráfico de red en busca de comportamientos sospechosos o firmas maliciosas y genera alertas.

IPS (Sistema de Prevención de Intrusiones): Herramienta activa que no solo detecta el tráfico malicioso, sino que lo bloquea de inmediato para evitar el ataque.

Antivirus: Software tradicional diseñado para detectar, bloquear y eliminar virus informáticos clásicos basándose principalmente en firmas.

Antimalware: Herramienta de espectro más amplio y moderno que combate amenazas avanzadas (troyanos, spyware, ransomware, exploits) mediante análisis heurístico y de comportamiento.

5. Normativa y buenas prácticas de uso

Reglamento General de Protección de Datos (RGPD): Normativa europea de obligado cumplimiento orientada a la privacidad, control y protección de los datos personales de los ciudadanos.

ISO/IEC 27001: Estándar internacional auditable que define los requisitos para diseñar, implementar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI).

Esquema Nacional de Seguridad (ENS): Marco normativo español que establece los principios básicos y requisitos mínimos de seguridad que deben cumplir las administraciones públicas y sus proveedores tecnológicos.

Datos sensibles: Categoría especial de información personal o corporativa (datos de salud, ideología, orientación sexual, datos financieros o secretos comerciales) que requiere un nivel de protección técnico y legal reforzado por el alto impacto que generaría su exposición.

Ciclo de vida de la información: Fases por las que pasa cualquier dato desde su origen hasta su final: creación/captura, almacenamiento, uso, compartición/distribución, archivado y destrucción segura.

6. Auditorias de seguridad

Ransomware.live: Sirve para monitorear en tiempo real los ataques y las víctimas de ransomware a nivel mundial

- **Rastreo de víctimas:** Escanea y monitorea de forma continua los "sitios de filtración de datos" (*data leak sites*) que los grupos de ransomware utilizan en la *dark web* para publicar la información robada a las empresas u organizaciones atacadas.
- **Listado de grupos activos:** Muestra qué bandas de ciberdelincuentes están operando (como *Qilin*, *Play*, *Akira*, entre otras), cuántas víctimas reclaman y qué sectores o países reciben más ataques.
- **Estadísticas y métricas:** Ofrece datos acumulados sobre el número total de víctimas en el año, tendencias de actividad mensual y detalles sobre si se conoce el monto del rescate o el tamaño de la filtración.
- **Indicadores de compromiso (IoCs) y vulnerabilidades:** Proporciona recursos, herramientas y avisos para equipos de respuesta a incidentes (CSIRT) y analistas de seguridad.

https://www.ransomware.live/

Shodan: Es un motor de búsqueda especializado en localizar dispositivos y sistemas conectados a Internet.

Para qué sirve Shodan

- **Encontrar dispositivos expuestos:** Localiza servidores, routers, cámaras de seguridad, sistemas industriales (SCADA) y dispositivos de Internet de las Cosas (IoT) que están accesibles públicamente en la red.
- **Auditoría de ciberseguridad:** Permite a los profesionales de la seguridad identificar fallos, puertos abiertos, software desactualizado y vulnerabilidades en su propia infraestructura antes de que un atacante los descubra.
- **Inteligencia de amenazas:** Ayuda a rastrear el alcance de ciertos tipos de malware, servicios mal configurados o la huella digital (superficie de ataque) de una organización.
- **Análisis de banners de servicio:** Muestra metadatos y respuestas técnicas que envían los servidores (como versiones de software y mensajes de bienvenida) sin necesidad de interactuar directamente con ellos.

https://www.shodan.io/

Hack The Box: Es una plataforma en línea de entrenamiento, evaluación y desarrollo de habilidades en ciberseguridad. Está diseñada tanto para entusiastas y profesionales individuales como para empresas.

- **Laboratorios prácticos:** Ofrece entornos interactivos (máquinas virtuales y retos) donde los usuarios pueden practicar técnicas de hackeo ético y defensa.
- **Equipos rojos y azules (*Red Team* y *Blue Team*):** Cuenta con rutas de aprendizaje orientadas al ataque (ofensivas), a la defensa y análisis de incidentes (defensivas).
- **Gamificación:** Utiliza un sistema de puntos, niveles y retos tipo *Capture The Flag* (CTF) para hacer el aprendizaje más dinámico. [
- **Comunidad global:** Cuenta con millones de usuarios en todo el mundo que comparten conocimientos y resoluciones (conocidas como *writeups*).
- **Enfoque empresarial:** Proporciona soluciones para que las compañías evalúen y capaciten a sus departamentos de seguridad informática.

https://www.hackthebox.com/

Nmap: es una herramienta de código abierto utilizada para la exploración de redes y auditorías de seguridad informática.

- **Descubrimiento de equipos (*Host Discovery*):** Identifica qué dispositivos (ordenadores, servidores, routers, móviles) están encendidos y conectados a una red.
- **Escaneo de puertos:** Localiza qué puertos TCP o UDP se encuentran abiertos, cerrados o filtrados en cada equipo.
- **Detección de servicios y versiones:** Determina qué programas o servicios (por ejemplo, servidores web, bases de datos) corren en esos puertos y qué versión exacta utilizan.
- **Identificación del sistema operativo (*OS Fingerprinting*):** Analiza las respuestas de los paquetes de red para adivinar el sistema operativo del dispositivo objetivo.

- **Análisis de vulnerabilidades:** Emplea scripts de automatización (*Nmap Scripting Engine* o NSE) para buscar fallos de seguridad o configuraciones débiles.

https://nmap.org/